

- [GR-Class Modules Guide](#)
 - [Roles at a Glance](#)
 - [Module Index](#)
 - [Detailed Module Reference](#)
 - [activity_requests](#)
 - [approvals](#)
 - [auth](#)
 - [certificates](#)
 - [change_requests](#)
 - [checklists](#)
 - [clients](#)
 - [compliance](#)
 - [contact](#)
 - [dashboard](#)
 - [documents](#)
 - [feedback](#)
 - [flags](#)
 - [incidents](#)
 - [jobs](#)
 - [non_conformities](#)
 - [notifications](#)
 - [payments](#)
 - [public](#)
 - [reports](#)
 - [search](#)
 - [site_static](#)
 - [support](#)
 - [surveyors](#)
 - [surveys](#)
 - [system](#)
 - [templates](#)
 - [toca](#)
 - [users](#)
 - [vessels](#)
 - [website](#)
 - [Module-wise Access Matrix \(one-screen reference\)](#)
 - [End-to-End Flow Recap \(which modules collaborate\)](#)
 - [How to Use This Document](#)

GR-Class Modules Guide

One-stop reference: every backend module, why it exists, who can access it, and where to look.

This document walks through **every module** under `src/modules/`. For each module you get:

- **Why this module exists** — the business problem it solves.
- **Who uses it** — the roles allowed on its routes.
- **What it does** — the key endpoints & their owners.
- **What it touches** — the main models / files.

Use this guide whenever someone asks "*why do we have a `toca` module?*" or "*can a SURVEYOR call `/payments`?*".

For the broader system context see `PRD.md` (business) and `SRS.md` (technical).

Roles at a Glance

Code	Full Name	One-line description
ADMIN	System Administrator	Full system control; user mgmt, compliance, system ops
GM	General Manager	Operational oversight; approves & assigns jobs, signs certs, payments
TM	Technical Manager	Technical authority; surveyors, templates, cert lifecycle, finalize jobs
TO	Technical Officer	Document & survey reviewer; raises and closes NCs
SURVEYOR	Marine Surveyor	Field execution; on-site surveys, checklists, GPS
CLIENT	Ship Owner / Operator	External user; raises jobs, downloads own certs
PUBLIC	(Unauthenticated)	Verify, marketing, contact form, surveyor application

The icons used in tables:  full •  partial / specific routes •  view-only •  no access.

Module Index

Quick links — alphabetical:

Module	Mount Point	Quick Purpose
activity_requests	/activity-requests	Ad-hoc work requests between clients & staff
approvals	/approvals	Generic multi-step internal approval workflow
auth	/auth	Login, logout, password reset, token refresh
certificates	/certificates	Certificate lifecycle + Certificate Authorities
change_requests	/change-requests	Post-issue corrections requested by clients
checklists	/checklists & /checklist-templates	Field checklists + templates
clients	/clients	Ship-owner organizations
compliance	/compliance	GDPR-style export & anonymize
contact	/contact	Public website contact-form inbox
dashboard	/dashboard	Role-aware aggregated metrics
documents	/documents	Generic file storage glued to entities
feedback	/customer-feedback , /portfolio-feedback	Job ratings + public testimonials
flags	/flags	Operational / feature flags (internal)
incidents	/incidents	Incident reporting & status

Module	Mount Point	Quick Purpose
jobs	/jobs	Heart of the system — full certification workflow
non_conformities	/non-conformities	Survey deficiencies (NCs)
notifications	/notifications	In-app notification inbox
payments	/payments	Invoicing, ledger, refunds, write-offs
public	/public	Unauthenticated verification & marketing
reports	/reports	Internal analytics exports
search	/search	Global, role-scoped search
site_static	mounted via website	Static CMS pages (FAQ, terms, etc.)
support	/support	Support ticketing
surveyors	/surveyors	Surveyor roster, applications, GPS, availability
surveys	/surveys	On-site survey execution & finalization
system	/system	Health, audit, metrics, ops
templates	/certificate-templates	Certificate PDF templates
toca	/toca	Transfer of Class workflow
users	/users	Self-service profile + admin user mgmt
vessels	/vessels	Vessel registry
website	/website	Marketing surface (videos, newsletter, static)

Detailed Module Reference

activity_requests

Mount: /activity-requests · Source: src/modules/activity_requests/

Why this module exists. Not every interaction between a client and the class society is a full certification job. Sometimes the client just needs the office to do something small — re-issue a paper, capture an incident, schedule a non-formal visit. **Activity requests** are the lightweight ticket type that catches all those "*please do X*" asks without polluting the main job pipeline.

Who can access it.

Action	Roles
Create request (POST /)	CLIENT, ADMIN, GM, TM
List / get one (GET /, GET /:id)	CLIENT, ADMIN, GM, TM, TO
Update status (PUT /:id/status)	ADMIN, GM, TM

SURVEYOR is intentionally **not** included — surveyors operate on assigned jobs, not on side requests.

Touches: **ActivityRequest** model. Visible on the client dashboard.

approvals

Mount: /approvals · Source: src/modules/approvals/

Why this module exists. Some internal decisions need more than one signoff (e.g., a sensitive cert revoke, a high-value invoice write-off). This module is a **generic, multi-step approval workflow** that other modules can plug into instead of inventing their own approval state machines.

Who can access it.

Action	Roles
Create approval chain (POST /)	ADMIN, GM, TM
Advance one step (PUT /:id/step)	ADMIN, GM, TM

CLIENT, **SURVEYOR**, and **TO** are **not** part of approval governance.

Touches: **Approval** model.

auth

Mount: /auth · Source: src/modules/auth/

Why this module exists. This is the **front door** for everyone — staff, surveyors, clients. It hands out and refreshes JWT access tokens, sets the secure refresh-token cookie, and runs the password-reset flow.

Who can access it.

Endpoint	Access
POST /login	PUBLIC (rate-limited)
POST /refresh-token	PUBLIC (rate-limited)
POST /forgot-password	PUBLIC
POST /reset-password	PUBLIC
POST /change-password	Any authenticated user
POST /logout	Any authenticated user

Why not gated by role? Because login itself decides the role — this is the only module where role-gating doesn't apply at the route level.

Touches: User model; emits emails for password reset; logs failed attempts.

certificates

Mount: /certificates (with sub-router at /authorities) · Source: src/modules/certificates/

Why this module exists. The certificate is the **product** the entire system delivers. This module owns:

1. **Certificate Types** (catalog of what the society issues),
2. **Certificate Authorities** (who legally issues them),
3. The full **certificate lifecycle**: draft → issue → sign → renew → revoke → restore,
4. The **public verify** lookup (also exposed in **public/**),
5. The PDF download.

Who can access it.

Action	Roles
GET /verify/:number	PUBLIC
GET /types, GET / (browse)	All authenticated roles (data-scoped: clients see only their own)
POST / / draft / generate	ADMIN, GM, TM
POST /:id/issue	ADMIN, GM
POST /:id/sign	ADMIN, GM
PUT /:id/suspend / revoke / restore / renew / reissue	ADMIN, TM
POST /types, PUT /types/:id (cert-type config)	ADMIN (some +TM)
/authorities/* CRUD	ADMIN (list/get also GM)
GET /:id/download / preview	All authenticated roles within scope

Who can NOT touch certificates? SURVEYOR (read-limited; never writes) and CLIENT (read own only; never writes).

Touches: Certificate, CertificateType, CertificateAuthority, CertificateHistory, Document (signed PDF asset).

change_requests

Mount: /change-requests · Source: src/modules/change_requests/

Why this module exists. After a certificate is issued, real life happens — typo on the vessel name, owner change, change of flag. **Change requests** are the formal channel for clients to ask for a post-issue correction without revoking the certificate themselves.

Who can access it.

Action	Roles
Create (POST /)	CLIENT, ADMIN, GM, TM
List / get	CLIENT (own), ADMIN, GM, TM

Action	Roles
Approve (PUT <code>/:id/approve</code>)	ADMIN , GM
Reject (PUT <code>/:id/reject</code>)	ADMIN , GM

TO and **SURVEYOR** cannot participate — change requests are governance decisions, not field work.

Touches: **ChangeRequest** model; often results in a certificate reissue on approval.

checklists

Mount: `/checklists` (job-bound) and `/checklist-templates` (template CMS) ·
Source: `src/modules/checklists/`

Why this module exists. A survey is not free-form — every certificate type has a **standardized checklist** that the surveyor must complete on board. This module separates **Templates** (managed by TM/ADMIN) from **Job-bound checklists** (filled by surveyors).

Who can access it.

Action	Roles
GET <code>/jobs/:jobId</code> (view checklist)	Any authenticated user with access to that job
PUT <code>/jobs/:jobId</code> (submit answers)	SURVEYOR
GET <code>/jobs/:jobId/get-upload-url</code> (upload signed scan)	SURVEYOR
Templates POST/PUT/DELETE	ADMIN
Templates GET (list / detail)	ADMIN , GM , TM , SURVEYOR
Templates GET <code>/job/:jobId/download</code>	SURVEYOR + internal staff

Touches: **ChecklistTemplate**, job-checklist data, **Document** (for signed scans), **CertificateType**.

clients

Mount: /clients · Source: src/modules/clients/

Why this module exists. A "client" is a **ship-owner organization**, not a single person. Multiple users can belong to one client. This module manages those organizations and their attached profile documents.

Who can access it.

Action	Roles
GET /profile/documents (own org)	CLIENT
POST / create	ADMIN, GM, TM
GET / list	ADMIN, GM, TM, TO
GET /:id, GET /:id/documents	ADMIN, GM, TM, TO
PUT /:id update	ADMIN, GM, TM
DELETE /:id	ADMIN

SURVEYOR does not need client-org data; CLIENT only sees their own org.

Touches: Client, User (org members), Document.

compliance

Mount: /compliance · Source: src/modules/compliance/

Why this module exists. GDPR / data-protection laws require the ability to **export everything we know about a person** and **anonymize them on request**. This module is the legal-compliance escape hatch.

Who can access it.

Action	Roles
GET /export/:id	ADMIN, CLIENT (own data)
POST /anonymize/:id	ADMIN

Anonymize is **destructive of PII** but preserves audit-log integrity (FK rows are kept; PII fields are scrubbed).

Touches: Many models — runs through **User**, **Client**, related rows.

contact

Mount: **/contact** (public POST is registered **before** other routes) · *Source:* **src/modules/contact/**

Why this module exists. Marketing site has a "Contact Us" form. This is the inbox. No login required to submit; staff handle the rest.

Who can access it.

Action	Roles
POST / submit enquiry	PUBLIC (rate-limited)
GET /, GET /:id, GET /stats, PATCH /:id/status	ADMIN , GM
DELETE /:id	ADMIN

Touches: Contact-enquiry model.

dashboard

Mount: **/dashboard** · *Source:* **src/modules/dashboard/**

Why this module exists. Every role wants a **landing page**. Instead of having each frontend make 6 different aggregator calls, this module returns a **role-aware bundle** of the right metrics for the logged-in user.

Who can access it.

Action	Roles
GET /	All authenticated roles

The shape of the response varies by role:

- **ADMIN** / **GM** → org-wide pipeline counters, financial summary, expiring certs.
- **TM** → surveyor utilization, NCs open, drafts pending.
- **TO** → docs to verify, surveys to review, NCs to close.

- **SURVEYOR** → assigned jobs, today's location.
- **CLIENT** → own jobs status, upcoming expiries.

Touches: Cross-module read-only aggregates.

documents

Mount: /documents · Source: src/modules/documents/

Why this module exists. Files (PDFs, photos, scans) attach to **many** entities — clients, vessels, jobs, surveys, certificates. Rather than each module reinventing storage, **everything** routes through this generic uploader with **entityType + entityId**.

Who can access it.

Action	Roles
GET /get-upload-url (presigned)	Authenticated, role-gated by entity context
POST /upload register metadata	ADMIN, GM, TM, SURVEYOR, CLIENT (depending on entity)
GET /:id / GET /:entityType/:entityId	Role-mirrored to entity (TO has read access too)
DELETE /:id	ADMIN, GM

Touches: Document model; AWS S3.

feedback

Mount: /customer-feedback and /portfolio-feedback · Source: src/modules/feedback/

Why this module exists. Two distinct concepts share this folder:

1. **Customer feedback** = a rating + comment a client gives **about a specific job**.
2. **Portfolio feedback** = a public-facing testimonial that admin curates onto the marketing site.

Who can access it.

Action	Roles
Submit job feedback	CLIENT
Read job feedback	ADMIN, GM (also the CLIENT who wrote it)
Portfolio feedback GET /public	PUBLIC
Portfolio submit	CLIENT
Portfolio visibility toggle	ADMIN

Touches: Feedback + portfolio feedback models.

flags

Mount: /flags · Source: src/modules/flags/

Why this module exists. Two purposes co-exist:

1. **Flag-state authorities** (the country whose flag a vessel flies) — used in vessel registration.
2. **Operational / feature flags** — internal toggles for staged rollouts.

Who can access it.

Action	Roles
POST /, PUT /:id	ADMIN
GET /, GET /:id	ADMIN, GM, TM, TO

CLIENT and SURVEYOR do **not** need to see the flag-administration table directly.

Touches: Flag model.

incidents

Mount: /incidents · Source: src/modules/incidents/

Why this module exists. When something **goes wrong** in the field — collision, near-miss, equipment failure, dispute — it isn't a job and isn't an activity request: it's an **incident**. This module records and tracks them through resolution.

Who can access it.

Action	Roles
POST / report	CLIENT, ADMIN, GM, TM
GET /, GET /:id	ADMIN, GM, TM, TO (read-only for TO)
PUT /:id/status	ADMIN, GM, TM

SURVEYOR does not own incidents (NCs are their channel for in-survey deficiencies).

Touches: Incident model.

jobs

Mount: /jobs · Source: src/modules/jobs/

Why this module exists. This is the heart of the platform. Every certification engagement lives as a **JobRequest**, walks through the lifecycle, and ends with a certificate. It is the most heavily role-gated module in the system.

State machine (high level):

```
draft → submitted → docs_verified → approved → assigned →  
authorized → survey_in_progress → submitted_for_review →  
reviewed → finalized → certificate_issued
```

plus side states **rejected**, **cancelled**, **sent_back**, **escalated**.

Who does what (key transitions):

Action	Endpoint	Role
Create job	POST /	CLIENT, ADMIN, GM
Verify documents	PUT /:id/verify-documents	TO (also ADMIN)
Approve request	PUT /:id/approve-request	GM, ADMIN
Assign surveyor	PUT /:id/assign	GM, ADMIN
Reassign / reschedule	PUT /:id/reassign, PUT /:id/reschedule	GM, ADMIN (TM for some)

Action	Endpoint	Role
Authorize survey	PUT <code>/:id/authorize-survey</code>	ADMIN, TM
Review submitted survey	PUT <code>/:id/review</code>	TO
Send back for correction	PUT <code>/:id/send-back</code>	TO, TM, ADMIN
Reject	PUT <code>/:id/reject</code>	GM, TM, ADMIN
Cancel	PUT <code>/:id/cancel</code>	CLIENT (own), GM, TM, ADMIN
Finalize	PUT <code>/:id/finalize</code>	TM, GM, ADMIN
Internal messages / notes	GET/POST <code>/messages</code> , etc.	TO, TM, GM, ADMIN
External messages	same routes (filtered)	All roles on the job

Read access: scoped — clients see own; surveyors see assigned; staff see all.

Touches: `JobRequest`, `JobHistory`, `Document`, `Notification`, `Survey`, `NonConformity`, `Certificate`.

non_conformities

Mount: `/non-conformities` · *Source:* `src/modules/non_conformities/`
(file: `nc.routes.js`)

Why this module exists. A non-conformity is a **deficiency found during a survey** — a missing safety device, an outdated drawing, a corroded plate. The system needs to record these formally, follow up, and **block job finalization until they're closed**.

Who can access it.

Action	Roles
Raise NC (<code>POST /</code>)	SURVEYOR, TO
List / get one	ADMIN, GM, TM, TO (SURVEYOR for own)
Close NC (<code>PUT /:id/close</code>)	TO, TM

Action	Roles
GET /job/:jobId	Internal roles

CLIENT does **not** see NCs directly — they see them surfaced through job history once communicated by staff.

Touches: **NonConformity** model. Open NCs gate **jobs.finalize**.

notifications

Mount: /notifications · Source: src/modules/notifications/

Why this module exists. Material events (assignment, status change, certificate issue, expiry approaching) need to **reach the user** without them having to refresh. This module is the in-app **inbox** that backs that. Email and FCM push are fan-out destinations from the same notification record.

Who can access it.

Action	Roles
GET / (own list)	Any authenticated user
PUT /:id/read, PUT /read-all	Any authenticated user

There is **no role gating** by code (**authorizeRoles** is not invoked) because each user only sees their own rows.

Touches: **Notification**. Powered by **services/notification.service.js**.

payments

Mount: /payments · Source: src/modules/payments/

Why this module exists. Certifications cost money. This module captures **invoices, payments, partials, refunds, write-offs, and the ledger** — the financial spine of the operation.

Who can access it.

Action	Roles
GET /, GET /summary	ADMIN, GM, TM, CLIENT (own only)
POST /invoice	ADMIN, GM, TM
PUT /:id/pay (mark paid)	ADMIN, GM, TM
Partial payment	ADMIN, GM, TM
Refund	ADMIN, GM
POST /writeoff	ADMIN
Ledger view	ADMIN, GM

SURVEYOR and TO are **not** part of finance.

Touches: Payment / invoice models, JobRequest.

public

Mount: /public · Source: src/modules/public/

Why this module exists. The world needs to **trust** GR-Class certificates. The /public namespace exposes **read-only, unauthenticated** lookups so a port-state inspector or charterer can verify a cert by number, look up a vessel by IMO, or watch promo videos — **with zero login friction.**

Who can access it.

Endpoint	Access
GET /certificate/verify/:number	PUBLIC
GET /vessel/:imo	PUBLIC
GET /website/videos	PUBLIC

All **PUBLIC** POSTs in the system are deliberately **NOT** here — this namespace is **read-only**. Posts (contact, surveyor application) live in their own modules with rate limiting.

Touches: Certificate, Vessel, marketing content.

reports

Mount: /reports · Source: src/modules/reports/

Why this module exists. Management needs **aggregated views**, not row-by-row drilldowns: revenue trends, surveyor productivity, NC trends, expiring-cert stats. This module produces those exports.

Who can access it.

Action	Roles
All GET /reports/*	ADMIN, GM, TM

TO, SURVEYOR, CLIENT are **excluded by router-level middleware**.

Touches: Cross-module read aggregates.

search

Mount: /search · Source: src/modules/search/

Why this module exists. A single search box that lets a user find a vessel, a job, or a certificate by free text — **without leaking other tenants' data**. Scoping is done **inside the service**, not at the route level.

Who can access it.

Action	Roles
GET /	Any authenticated user (results scoped by role)
- CLIENT → only matches under their own client_id. - SURVEYOR → only matches on jobs assigned to them. - Internal staff → unrestricted (within tenant).	

Touches: Vessel, JobRequest, Certificate.

site_static

Mount: mounted under **website** at `/website/static-content` (also stand-alone at `/site-static` if used) · *Source:* `src/modules/site_static/`

Why this module exists. The marketing site has pages — *About*, *Terms*, *Privacy*, *FAQ*. Editing those should not require a code deploy. This is a tiny CMS for those.

Who can access it.

Action	Roles
<code>GET /</code> , <code>GET /:slug</code>	PUBLIC (drafts visible only with admin token)
<code>POST</code> , <code>PUT</code> , <code>DELETE</code>	ADMIN

Touches: `SiteStaticContent` (or similar) model.

support

Mount: `/support` · *Source:* `src/modules/support/`

Why this module exists. Users (especially clients) get stuck. **Support tickets** are the catch-all way to ask for help that is **not** a job, **not** an activity, and **not** an incident.

Who can access it.

Action	Roles
<code>POST /</code> open ticket	Any authenticated user
<code>GET /</code> , <code>GET /:id</code>	Any authenticated user (ownership enforced in service)
<code>PUT /:id/status</code>	ADMIN , GM

Touches: `SupportTicket`.

surveyors

Mount: `/surveyors` · *Source:* `src/modules/surveyors/`

Why this module exists. Surveyors don't just appear out of thin air — they **apply**, **get vetted**, **get onboarded**, and then need ongoing operational tools (availability calendar,

live GPS reporting). This module is **everything about being a surveyor**, both pre- and post-hire.

Who can access it.

Action	Roles
POST /apply	PUBLIC (rate-limited)
GET /get-upload-url (CV/docs)	PUBLIC (rate-limited)
GET /applications	ADMIN, TM
PUT /applications/:id/review	ADMIN, TM
POST / (create surveyor account)	ADMIN, TM
GET /:id/profile	ADMIN, GM, TM, SURVEYOR (own)
PUT /:id/profile	ADMIN, TM
POST /availability, POST /location	SURVEYOR

CLIENT does not need to see the surveyor roster.

Touches: User (surveyor role), surveyor profile/application/availability/GPS data.

surveys

Mount: /surveys · Source: src/modules/surveys/

Why this module exists. The **on-site execution layer**. Once a job is assigned, the surveyor opens it, starts a survey session, captures GPS + photos + checklist, and submits. Then TM/GM finalize or send back.

Who can access it.

Action	Roles
POST /start (begin session, capture GPS)	SURVEYOR
POST /jobs/:jobId/proof (upload photos)	SURVEYOR
POST / submit	SURVEYOR
GET /jobs/:jobId/timeline, etc.	Internal staff + SURVEYOR (own)

Action	Roles
PUT /jobs/:jobId/finalize	TM (with preventSelfApproval)
Rework / flag	TM, GM
List	ADMIN, GM, TM, TO

CLIENT does **not** read raw survey records — they receive the resulting certificate.

Touches: Survey, JobRequest, Document (proofs), GPS pings, geo-fence rules.

system

Mount: /system · Source: src/modules/system/

Why this module exists. DevOps / SRE / on-call need a way to **probe the platform** and **operate it** — health, version, audit logs, retry queues, force-logout, feature flags, migration state. This is that surface.

Who can access it.

Action	Roles
GET /health, /readiness, /version	Any authenticated user
GET /metrics, /audit-logs, /access-policies, etc.	ADMIN
POST /cache/clear, /queue/retry, etc.	ADMIN

Touches: Audit log, feature flag, queue / migration meta tables.

templates

Mount: /certificate-templates · Source: src/modules/templates/

Why this module exists. The **PDF look-and-feel** of certificates is configurable per certificate type / locale. This module manages those template definitions (HTML/Handlebars-style). Distinct from **checklist-templates**.

Who can access it.

Action	Roles
POST /, PUT /:id, DELETE /:id	ADMIN
GET /, GET /:id	ADMIN, GM, TM

TO, SURVEYOR, CLIENT have **no business** with template authoring.

Touches: CertificateTemplate, CertificateType.

toca

Mount: /toca · Source: src/modules/toca/

Why this module exists. TOCA = Transfer of Class. When a vessel moves from another classification society to GR-Class (or vice versa), there's a documented handover — class records, surveys, retention documents. This module captures those transfer records.

Who can access it.

Action	Roles
POST / create transfer	TM
GET / list	ADMIN, GM, TM
PUT /:id/status accept / reject	TM, ADMIN

TO, SURVEYOR, CLIENT are not part of TOCA governance.

Touches: Toca, Vessel.

users

Mount: /users · Source: src/modules/users/

Why this module exists. Two purposes:

1. **Self-service:** any logged-in user manages their own profile, profile picture, FCM token.
2. **Admin user management:** ADMIN provisions, deactivates, and inspects user accounts.

Who can access it.

Action	Roles
GET/PUT /me, PUT /profile-pic, PUT /fcm-token	Any authenticated user (self)
GET/POST/PUT/DELETE /:id, PUT /:id/status	ADMIN

Touches: User.

vessels

Mount: /vessels · Source: src/modules/vessels/

Why this module exists. Vessels are the **subject** of every certification. Each vessel has an IMO number, a flag state, an owner (client). This is the registry.

Who can access it.

Action	Roles
GET / list	ADMIN, GM, TM, TO, CLIENT (own only)
GET /:id detail	All authenticated incl. SURVEYOR (own jobs)
POST /, PUT /:id	ADMIN, GM, TM
GET /client/:clientId	Internal staff

Touches: Vessel, Client, Flag.

website

Mount: /website · Source: src/modules/website/ (composes site_static, newsletter, video routes)

Why this module exists. The **public marketing surface** rolled up into one router: static CMS, video library, newsletter subscribe + admin broadcast.

Who can access it.

Action	Roles
GET /videos, /static-content, /newsletter/subscribe	PUBLIC
POST /videos, PUT /videos/:id, DELETE /videos/:id	ADMIN
POST /newsletter/broadcast, GET /newsletter/subscribers	ADMIN

Touches: Video assets, newsletter subscribers, [SiteStaticContent](#).

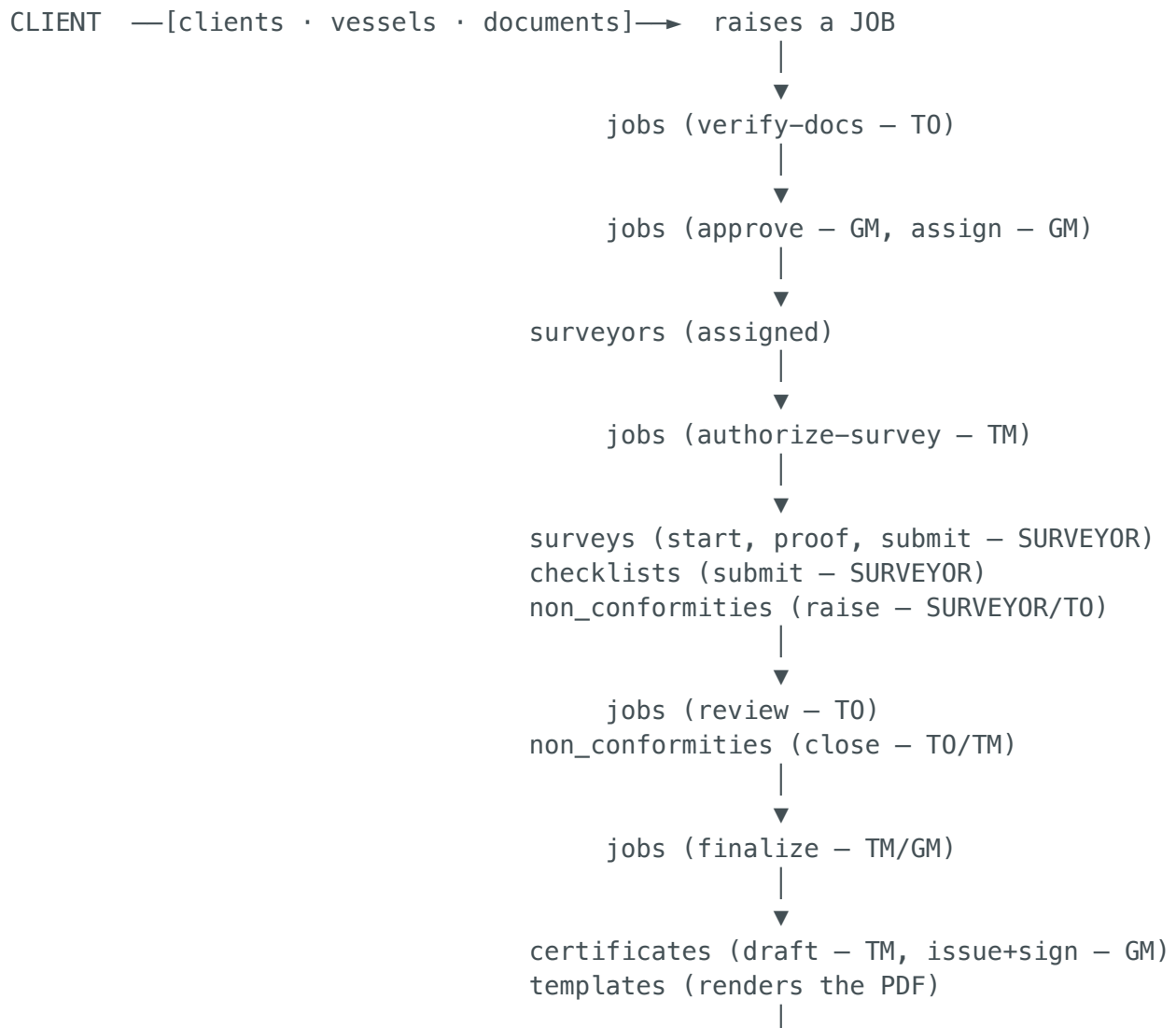
Module-wise Access Matrix (one-screen reference)

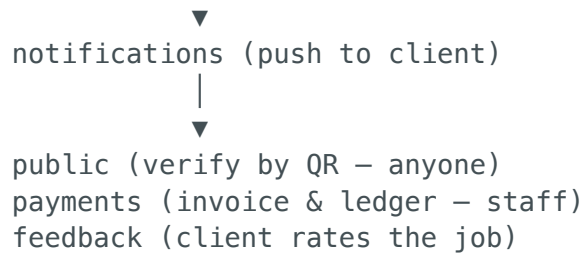
 Full •  Specific actions •  View only •  No access							
Module	ADMIN	GM	TM	TO	SURVEYOR	CLIENT	PUBLIC
auth							 (login/reset)
users		 self	 self	 self	 self	 self	
clients						 own	
vessels					 own jobs	 own	 verify by IMO
surveyors					 self		 apply
jobs					 own	 own	
surveys				 review	 field		
checklists (job-bound)					 submit		
checklist- templates							
certificates		 issue/sign	 lifecycle			 own	 verify

Module	ADMIN	GM	TM	TO	SURVEYOR	CLIENT	PUBLIC
cert authorities	✓	👁️	🔒	🔒	🔒	🔒	🔒
templates (cert PDF)	✓	👁️	👁️	🔒	🔒	🔒	🔒
documents	✓	✓	✓	👁️	✓ scoped	🎯 own	🔒
non-conformities	✓	✓	✓	✓	🎯 raise	🔒	🔒
approvals	✓	✓	✓	🔒	🔒	🔒	🔒
change-requests	✓	✓	🎯	🔒	🔒	✓ submit	🔒
activity-requests	✓	✓	✓	👁️	🔒	✓	🔒
incidents	✓	✓	✓	👁️	🔒	✓ report	🔒
toca	✓	✓	✓	🔒	🔒	🔒	🔒
flags	✓	👁️	👁️	👁️	🔒	🔒	🔒
payments	✓	✓	🎯	🔒	🔒	👁️ own	🔒
reports	✓	✓	✓	🔒	🔒	🔒	🔒
dashboard	✓	✓	✓	✓	✓	✓	🔒
search	✓	✓	✓	✓	✓ scoped	✓ scoped	🔒
notifications	✓ own	✓ own	✓ own	✓ own	✓ own	✓ own	🔒
support	✓	✓	👁️ own	👁️ own	👁️ own	✓ open	🔒
feedback (job)	✓	✓	🔒	🔒	🔒	✓ submit	🔒
feedback (portfolio)	✓ moderate	🔒	🔒	🔒	🔒	✓ submit	🎯 read

Module	ADMIN	GM	TM	TO	SURVEYOR	CLIENT	PUBLIC
compliance	✓	🔒	🔒	🔒	🔒	🎯 own export	🔒
system	✓	🎯 health	🎯 health	🎯 health	🎯 health	🎯 health	🔒
public	🎯	🎯	🎯	🎯	🎯	🎯	✓
website	✓ admin	🔒	🔒	🔒	🔒	🔒	✓ read
contact	✓	✓	🔒	🔒	🔒	🔒	✓ submit
site-static (via website)	✓	🔒	🔒	🔒	🔒	🔒	✓ read

End-to-End Flow Recap (which modules collaborate)





Side-channels that run alongside the main flow:

- [support](#), [activity_requests](#), [change_requests](#), [incidents](#) — non-job tickets.
- [dashboard](#), [reports](#), [search](#) — visibility / analytics.
- [compliance](#), [system](#), [flags](#), [users](#) — governance & ops.
- [website](#), [contact](#), [site_static](#), [feedback \(portfolio\)](#), [surveyors \(apply\)](#) — public-facing acquisition surface.

How to Use This Document

- **New engineer onboarding?** Read [PRD.md](#) → this guide → [SRS.md](#) in that order.
- **Confused about whether a role can hit an endpoint?** Find the module above → check the access table.
- **Adding a new endpoint?** Decide which module owns it, add an entry here under that module, and gate it via [authorizeRoles\(...\)](#) in the route file.
- **Reviewing a PR that touches RBAC?** Cross-check that this document and the route file agree.

Last updated: April 2026 · GR-Class Backend Team